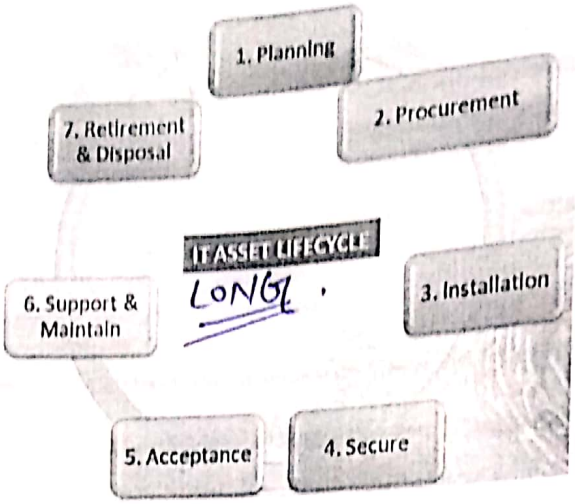
Both plans must integrate [illegible]

Topic no 52: Role Of An IT Asset In Enterprise Security

- **What is an IT asset?** MCQS.

  = An IT asset is any resource such as hardware, software, information, human resource, or facility owned or utilized by the organization for IT processing

Scanned with CamScanner



1. PLANNING
- Requirements
- Owner & Risk Owner
- High Level Design
- Budget Approvals
- Project Planning

2. PROCUREMENT
- RFP
- Vendor Selection
- PO
- Contract & SLA
- Kick-Off Meeting

3. INSTALLATION
- Site Preparation
- Delivery
- Configuration
- Testing
- Commissioning

4. SECURE
- Security Controls
- Security Checklist
- Security SOP
- Security Testing

5. ACCEPTANCE
- Test Scripts
- UAT
- Security Accreditation
- Commissioning Sign-off
- Change Management

6. SUPPORT/MAINTAIN
- Vendor Support
- Maintenance/Repair
- Change Requests
- Renewals & Upgrades
- Regular Updates
- Monitoring & Audits

7. RETIRE/DISPOSE
- Decommission
- Dispose/Salvage
- Update Inventory

- Asset Owner: a person in the org responsible for managing an asset (e.g. for laptop)
- Risk owner: manages risks associated with the IT asset. Authorized to make decisions associated with managing risks, and in a management position
- **Acceptable Use (Of IT Assets):**
  - Laptops
  - Mobiles

Scanned with CamScanner

Chapter 3

Security Transformation Stage

Topic no 55: Revisit Of Security Transformation Model

- **Security hardening:**
  - IT assets such as hardware and software come with default (insecure) configurations which become the basis for attacks

Scanned with CamScanner

- Typical case in point: username and password: "admin, admin"
- System by reducing its surface of vulnerability, which is larger when a system performs more functions; in principle a single-function system is more secure than a multipurpose one.

- **Patching:** MCQ + Short
- Fixing vulnerabilities (which may be exploited by malware or attackers) in software or firmware with vendor released patches (auto or manual updates)
- Patches are also called fixes
- **Patching considerations:**
  - Vendors release patch when they become aware of a vulnerability
  - Patches may be rolled up into a release
  - Off-the shelf software works well but testing reqd for customized instances
- **Hardening:** includes additional steps beyond patching to limit the ways a hacker or malware could gain entry.

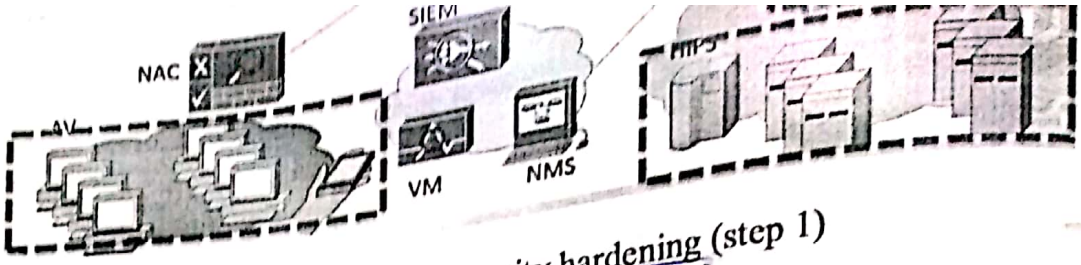
  Accomplished by turning on only the ports and services required, secure configuration of services & additional steps to limit system access

- **Note that both hardening & patching are required**
  - Hardening prevents existing and future vulnerabilities by tightening configuration
  - Patching is more of a vendor driven process but essential nonetheless

Topic no 56: Security Hardening Strategy

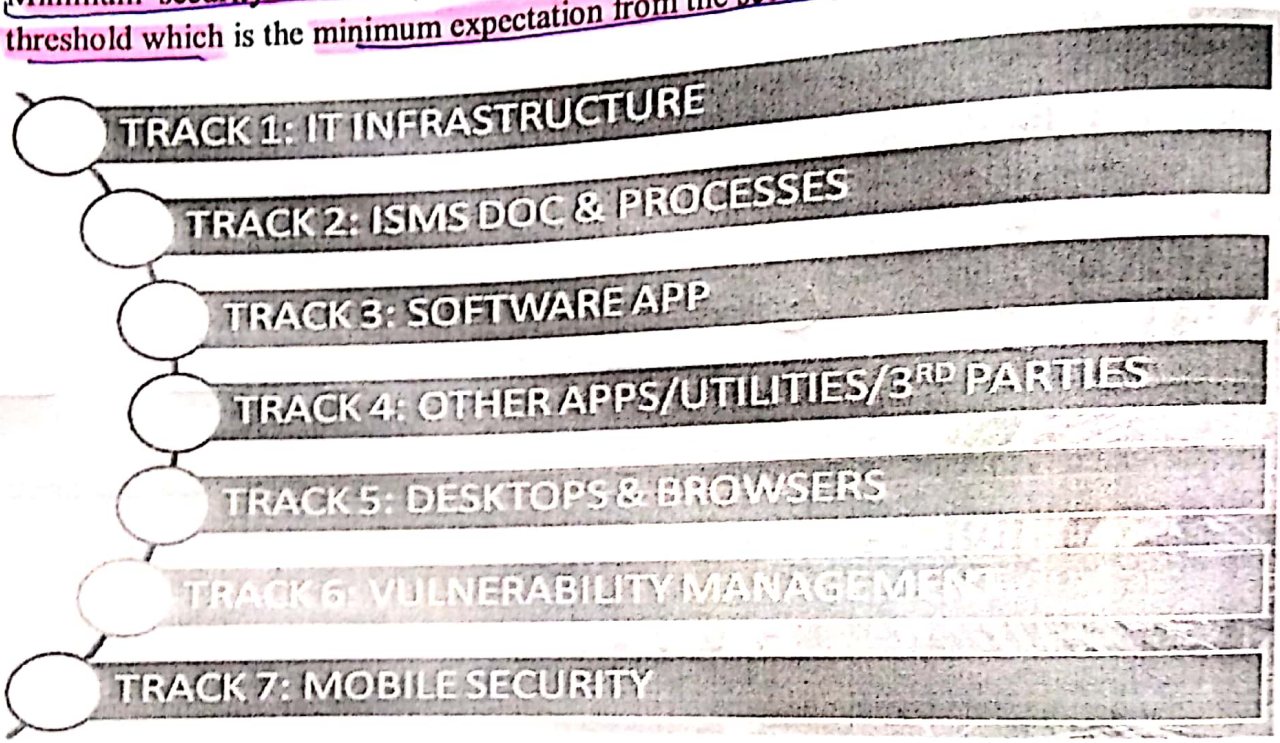
- Depending upon the (1) size and (2) type of the organization, there will be dozens, hundreds, or even thousands of IT assets to secure
- Priority is a key factor in all security undertakings
- Prioritize what is most important and needs to be done first
- Cascade as we go along

Scanned with CamScanner



- Separate security engineering (Step 3) from security hardening (step 1)
- Security engineering requires more thorough working,so will slow down the security implementatio
- Do the low hanging fruit first (security hardening)
- Minimum security baseline (MSB) refers to the obvious assets which need to be secured an threshold which is the minimum expectation from the security program

MCQS

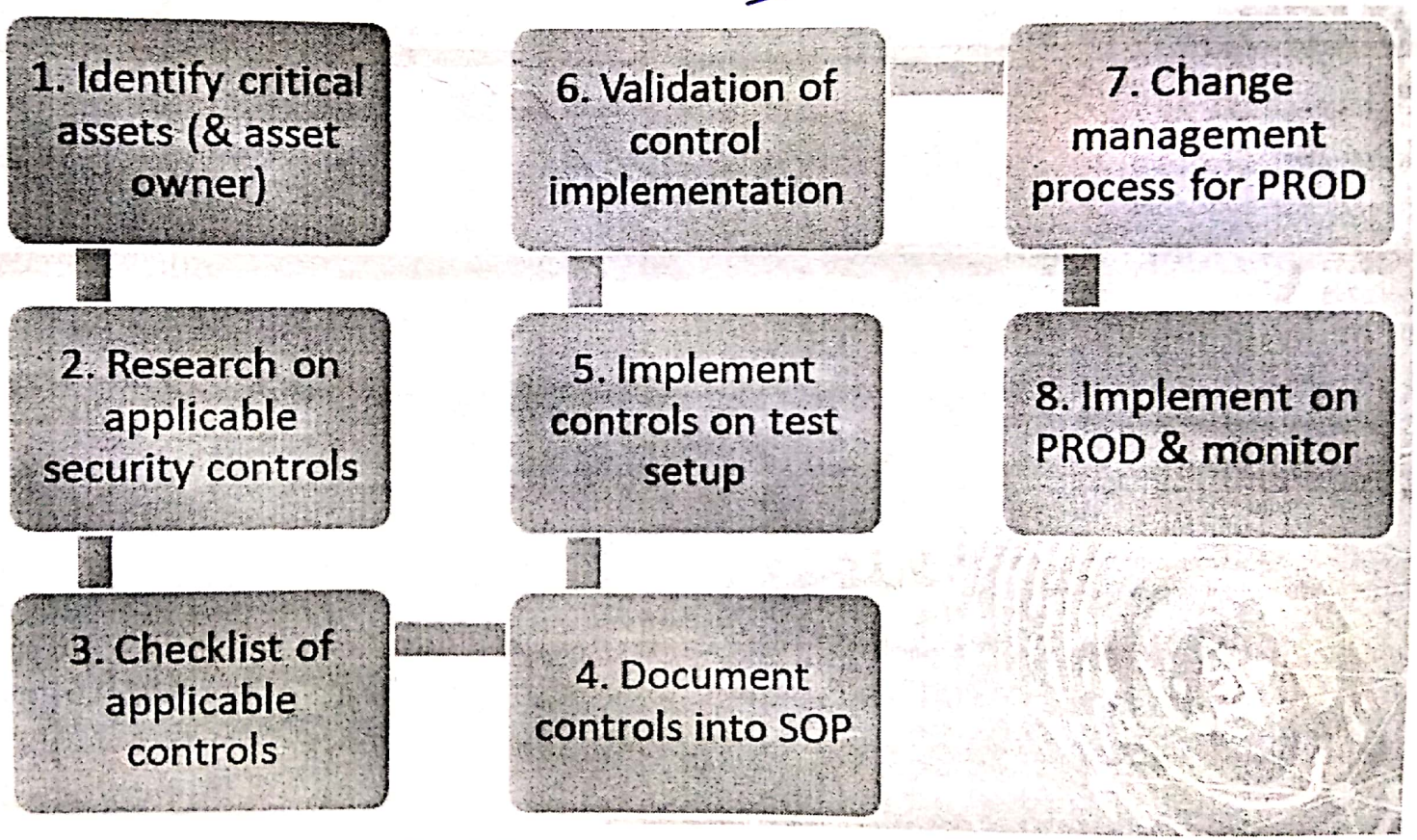


- For a successful security transformation project, good planning, organization, and effective pr management is essential.

Scanned with CamScanner

Topic no 59: 8 Step Methodology – Security Hardening (1)

- What is the 8 step security hardening methodology? LONG.



Scanned with CamScanner

- **Benefits:** of Security Hardening.

  - Process for security hardening
  - Discipline to always follow the same steps
  - Helps avoid missing any steps in the process
  - Gives team clarity on what to do and what sequence to follow

Scanned with CamScanner

STEP	DESCRIPTION	PERFORMED BY	FACILITATED BY
1	IDENTIFY CRITICAL ASSETS (& ASSET OWNER)	ISMC	HEAD OF IT SECTION
2	RESEARCH APPLICABLE SECURITY CONTROLS	INFOSEC TEAM	ISMC
3	CHECLIST OF APPLICABLE SECURITY CONTROLS	INFOSEC TEAM	TEAM LEAD
4	DOCUMENT CONTROLS INTO SOP	TEAM LEAD	INFOSEC TEAM
5	IMPLEMENT CONTROLS ON TEST SETUP	IT OPERATIONS TEAM	TEAM LEAD
6	VALIDATION OF CONTROL IMPLEMENTATION	INFOSEC TEAM	IT OPERATIONS TEAM
7	CHANGE MANAGEMENT PROCESS FOR PRODUCTION	TEAM LEAD	ISMC
8	PRODUCTION & MONITOR	IT OPERATIONS TEAM	TEAM LEAD

Topic no 60: 8 Step Methodology – Security Hardening (2)

- **Step 1: Identify Critical Assets & Asset Owner:**
  - Asset inventory & infrastructure diagram
  - Examine risks
  - Analyze assets at a high level and prioritize
  - Minimum security baseline (MSB)
  - Break into phases
- **Step 2: Research on applicable security controls**
  - CIS, DISA
  - Search on google
  - Review standards/frameworks (ISO27001, PCI, etc)
  - Look at OWASP, CSA, NIST, CIS Top 20
  - Selection of controls

Scanned with CamScanner

- **Step 3: Checklist of applicable security controls**
  - Checklist for progress tracking
  - Share with appropriate IT team
  - Forms record for controls trail
- **Step 4: Document controls into SOP**
  - Enter controls set into draft SOP
  - Who will do what when, (and briefly how)
  - Get Dept Head agreement and sign-off on checklist and SOP

LONG **Topic no 61: 8 Step Methodology – Security Hardening (3)**

- **Step 5: Implement controls on test setup**
  - Relevant IT team to implement controls on test setup
  - Update checklist
  - Update SOP (if necessary)
  - Send checklist back to InfoSec team
- **Step 6: Validation of control implementation (by InfoSec team)**
  - InfoSec resource with relevant domain knowledge
  - Conduct preparation before actual validation (study controls)
  - Update checklist with status column
- **Step 7: Change management process for PRODUCTION:**
  - ISMC receives validation status from InfoSec team
  - Relevant dept head takes up change management process and prepares for shifting to PROD
  - Rollback, impact etc
- **Step 8: Implement on PROD & monitor:**
  - Monitor closely for 24-48 hours after moving to PROD
  - Rollback in case of unforeseen circumstances
  - IT team SOP finalized and now ops task

Scanned with CamScanner